경력기술서 — 최규철 · GraeEye BI 개발 (비즈플러그, 2026.06 ~ 현재)

프로젝트 개요

항목	내용
제품	GraeEye — 드래그앤드롭 방식의 셀프서비스 BI/대시보드 편집기. 업무 DB(MySQL/MariaDB·PostgreSQL·Oracle)에 직접 질의해 그리드·차트·KPI·피벗·지도 위젯을 배치하고 미리보기·외부 공유·모바일 뷰어로 배포
차별점	시스템 DB로 임베디드 PGlite를 채택해 인터넷이 없는 폐쇄망에 압축 파일 하나로 설치. AI(NL→SQL·RAG) 모듈은 선택 사항이며 첫 고객은 AI를 끈 BI 에디션 사용
기간	2026-06-22(입사) ~ 현재, 5개월 · 리포 이력은 2026-07-06 재정비 이후 기준
소속·역할	비즈플러그 개발팀 정규직 · 팀 내 유일한 개발자로 프런트·백엔드·배포·테스트 인프라·문서·고객 현장 설치 전담 (기획·QC는 별도 담당)
고객	서울시설공단 폐쇄망 개발서버에 v0.5.0 설치(2026.08) → v0.6 재배포(2026.10) 운영 중
규모	머지 PR 1,114건(전부 본인 작성), 커밋 4,897건, 테스트 파일 1,573개(단위·HTTP 경계·실DB 통합) + E2E 16, 작업기록 문서 362편, 사용자 메뉴얼 36개 기능, ADR 3편

기술 스택

- 프런트: React 19, TypeScript, Vite(멀티 엔트리), Zustand, Tailwind CSS, ECharts 6, D3, CodeMirror 6, @dnd-kit, TanStack Virtual
- 백엔드: Node.js 20(ESM), Express, JWT(세션 결속)·OAuth2/OIDC(PKCE)·SAML 2.0, 5단계 RBAC, WebSocket 실시간 서버
- DB: mysql2 / pg / oracledb(Thin) 드라이버, 임베디드 PGlite 또는 PostgreSQL 시스템 DB(마이그레이션 32개), node-sql-parser(SQL AST)
- 데이터·내보내기: exceljs, jszip, html2canvas, jspdf
- AI(선택 모듈): FastAPI + LangChain + ChromaDB RAG 서버, OpenAI/Claude/Ollama 라우팅 게이트웨이
- 테스트·CI: vitest, Testing Library, node:test, Playwright, GitHub Actions(단위 → MySQL 방언 통합 → E2E, 실 PostgreSQL 잡), Docker 테스트 DB(MySQL 8·MariaDB 10.1·PG 16/18·Oracle XE 21c)
- 배포: 오프라인 패키지 스크립트, 원클릭 설치, systemd, Apache 리버스 프록시 + TLS 자동화, 사전압축(gz/br), 코드 난독화

주요 성과 (문제 → 접근 → 개선)

1. 다중 DB 방언 단일 조립 엔진과 쿼리 빌더 재편

- 문제: SQL 조립 경로가 두 벌(빌더·고급 쿼리)로 중복되고, 필터 리터럴이 타입 무관 문자열이라 Oracle 날짜·boolean에서 무음 오답. 보안 감사에서 별칭 raw 삽입·인용 구분자 breakout 등 인젝션 경로 확인.
- 접근: 순수 함수 조립 엔진 1벌 + 방언(인용·LIMIT/TOP·타입 인지 리터럴)은 데이터 테이블로 분리. 이스케이프 함수에 dbType을 컴파일 타임에 강제. 위험 동작(DELETE 라디오)은 UI에서 제거하고 스키마 기반 예제·FK 기반 JOIN 제안·GROUP BY 누락 배너 추가.
- 개선: MySQL·PostgreSQL·Oracle 네이티브 SQL을 한 엔진에서 생성, 무배선 코드 3,079줄 제거, 10월 전수조사에서 클라이언트 SQL 조립 정본 전체 "안전" 판정. [PR #37, 보안_SQL인젝션_감사_2026-07]

2. 운영 DB 보호 관문 — 조회 상한·실행 시간 상한·끊김 취소

- 문제: 전량 조회 경로가 끝까지 받아 19.8만 행 피벗 하나가 79MB 응답·서버 메모리 +473MB. 일반 조회에 시간 상한이 없어 pg_sleep 12초가 그대로 응답. 요청을 끊어도 DB에는 좀비 쿼리가 active로 남음. 임베디드 PGlite는 단일 응답 16MB 초과 시 인스턴스가 붕괴해 로그인까지 불능.
- 접근: 고객 서버 사양(4코어·16GB)과 "서버 메모리 ≈ 응답 크기 × 5~7배" 실측에서 역산해 화면 3만 행·12MB / 내보내기 10만 행·48MB / 임베디드 12MB 상한을 용도별로 설정. PG statement_timeout·MySQL MAX_EXECUTION_TIME·Oracle callTimeout로 방언별 시간 상한, 기본값은 5명×3회 동시 부하 실측(최대 4.65초 → 10배 규칙)으로 도출. 요청 끊김 시 pg_cancel_backend / KILL CONNECTION / break()로 읽기 쿼리 취소. 업계 BI 6종 상한 정책을 1차 자료로 조사해 설계 근거로 사용.
- 개선: 잘림 사유를 응답·칩·내보내기 파일에 일관 고지. 실엔진 시험이 상한 밖에서 돌던 COUNT(4억 행, 176초 → 2.3초)를 추가 적발. Docker 3종 DB 상한 시험 15/15, 5명 동시 90건 p99 3.4초·60초 초과 0건. [PR #1013, #1047, #1051, #1126]

3. 보안 — 인젝션 전수조사에서 SQL 분류기·연결 소유권·기준선 수리까지

- 문제: 내장 샘플 데이터소스 경로가 요청 본문 문자열만으로 판정되고 인증이 없어, 콤마 조인 한 줄로 미인증 요청이 세션 토큰·암호화 접속정보 테이블을 읽을 수 있었음(P0). SQL 쓰기 판정이 키워드 앞머리 목록이라 DROP SCHEMA·CREATE VIEW 통과, 주석·세미콜론 해석이 분류기와 실행부에서 달라 null 판정 입력이 실제로 DROP 실행. 커밋된 JWT 기본 문구로 서명한 super_admin 토큰이 통과.
- 접근: 서버가 해석한 연결 행 기준 표식 + 로그인 필수 / SQL AST 허용목록(단일 SELECT·허용 테이블·함수) / 읽기 전용 트랜잭션의 3겹 방어. 쓰기 판정은 PG(중첩 주석·tag·E-문자열)·MySQL(#·/*!·3모드)·Oracle(q-인용)을 모두 읽는 렉서 기반 분류기로 교체,

방언별 해석의 합집합으로 판정. 등록 연결은 소유자·공용·super_admin만 해석하는 리졸버로 IDOR 차단. JWT 약한 시크릿은 기동 시 폐기·자동 생성, CORS 설정 API 인증·형식 검증.

- 개선: 독립 보안 리뷰 2라운드(위조저항 12/12) + 브라우저 실측으로 P0·P1 전건 종결. 분류기 표 기반 시험 138건·뮤턴트 39종 전부 사망. 처음부터 동작한 적 없던 OAuth 로그인을 가짜 IdP HTTP 경계 시험 9건과 함께 복구. [PR #871, #943~#952, #920~#935, #1118, #919]

4. 그리드 데이터 신뢰성 — 합계 정합·서버 사이드 피벗·DB 대조

- 문제: 합계 행이 화면 표시 행이 아닌 원본 배열을 집계해 필터 후에도 전체 합계가 표시. 브라우저 === 필터와 MySQL 콜레이션(PAD SPACE·대소문자 무시)의 비교 규칙이 달라 같은 조건에 DB 3,082행 / 화면 3,020행. 행×열 분할 피벗은 수동 메저 생성으로만 가능.
- 접근: 집계 축을 "화면에 그리는 배열" 하나로 통일하고 전체 건수를 알 때만 "로드분" 칩 표시. 헤더 필터를 원본 DB WHERE로 위임. 열 분할은 DISTINCT로 값 발견 → CASE WHEN 자동 생성 → N단 헤더의 서버 사이드 자동 피벗 + 4계층 정합성 검증(캐치올 열·Σ분할열=합계열 대사 칩·타입/카디널리티 가드·가산성 메타데이터). "DB와 대조" 기능은 실행 SQL을 감싼 집계 쿼리 1회로 건수·합/최소/최대를 BigInt 정밀 비교.
- 개선: 필터 후 합계 오답·도달 불능 필터 값(17종 중 3종 누락) 해소. 경쟁 BI 요구 19항목 갭 분석 → P0 5·P1 6건을 21 PR로 2일 내 완결(테스트 2,213 → 2,727). 4계층 구현 후 코드리뷰 7라운드로 37건 발견·36건 수정. [PR #614, #955~#965, #503~#512, 합계정합_구현_2026-08-11]

5. 차트 — 겹침 근본 원인 추적·우클릭 3계층 설정·매핑 안정화

- 문제: 차트 겹침 결함 4건이 모두 배포 후 사용자 육안으로 발견, 겹침을 단정하는 테스트 0건. 세부 옵션을 우측 패널에 전부 넣으면 패널이 비대해짐. QC 결함 9건(유형 전환 시 축 구성 파괴 등).
- 접근: ECharts 6 소스까지 추적해 원인이 nameGap이 아니라 deprecated grid.containLabel이 레거시 레이아웃을 타며 축 이름 자동 회피를 끄는 것임을 확인. 옵션을 실제 SSR 렌더해 텍스트 최종 좌표로 겹침을 판정하는 검증 하네스(프로덕션 코드 0줄) 작성. 설정 진입을 우클릭 3계층(원클릭 토글 / 인라인 팝오버 / 패널 딥링크)으로 재배치. 히트맵·펀치카드 "지표 매트릭스", 스캐터·폭포수·레이더 매핑 정본화.
- 개선: 9 차트 × 3 크기 × 2 데이터 = 54조합 회귀 표로 플롯 확대 54/54 증명. 하네스가 이후 라벨 드래그 기능이 만든 회귀(겹침 0쌍 → 9쌍)를 자동 적발. 설정 탭 5개 → 2개. 고객 인포그래픽 요건(도넛 중앙 총계·배지 라벨) 반영. [차트_겹침_근본해결_2026-08-13, PR #345~#352, #1119~#1122]

6. 자동 탐색·드릴 — 계층 선언 없는 탐색 UX

- 문제: 기존 BI는 드릴다운 계층을 미리 선언해야 하강 가능. 월별 집계에서 이상값을 봐도 그 자리에서 쪼갤 수 없고 무엇으로 쪼갤 수 있는지 화면이 알려주지 않음.
- 접근: 차트 클릭 → 분할 후보 상위 3개를 실제 GROUP BY 프로브 수치와 함께 제안 → 선택 시 하강. 판단 로직은 순수 모듈로 분리하고 브리지는 조회 경로가 남긴 출발 SQL을 읽기만 함. 범위 원칙 "이름·코멘트에서 추정한 의미는 후보 자격·점수에 쓰지 않는다, 미확인은 제외와 구별한다(부당 제외 0 = 하드 게이트)"를 실측 감사로 확정. 드릴다운·드릴스루·드릴크로스 3종 사용성 개선, 드릴 링크 화살표 오버레이.
- 개선: 설정 패널로 나가지 않고 하강하는 UX 제공. 구현 중 기존 결함 7건(미리보기 그리드가 컴포넌트 SQL 무시 등) 수정. 교차검토 최대 12차 왕복 후 머지. [PR #647, 탐색_범위원칙_개정_2026-09-18]

7. no-AI 시맨틱 레이어·시각화 추천 엔진

- 문제: 첫 배포가 AI 비활성이라 "데이터셋을 드롭하면 즉시 차트가 그려지는" UX를 LLM 없이 결정적 규칙만으로 구현해야 했음.
- 접근: 타입 → PK/FK → 이름·코멘트 → 값 통계 폴백의 결정적 역할 분류기(컬럼명이 무의미해도 샘플 값 분포로 판정), 차트 27종 가능/불가 서명 판별, SQL AST + 결과 프로파일 기반 추천(템플릿 19종). 품질은 시드 난수 블라인드 테스트 720회·골든셋 51케이스·가중치 2,294조합 캘리브레이션 하네스로 상시 측정.
- 개선: 블라인드 테스트 첫 실행에서 실결함(조밀 정수 소범위를 코드로 오판) 적발 후 확신 판정 정확도 100%. 골든셋 top-1 수용률 100% 유지. 10월 역할 분류기 연결 감사로 정정이 집계를 덮는 결함 등을 PR 스택으로 수리. [PR #21, #123, #1123~#1172]

8. 폐쇄망 오프라인 배포 체계와 고객 현장 설치·재배포

- 문제: 고객은 인터넷·USB 반입이 제한된 폐쇄망(Rocky Linux 9.8, Apache, HTTP)이고 설치자가 비개발자일 수 있음. 재배포 전 실측에서 로그인 전 받아야 할 JS/CSS가 무압축 30.2MB, 고객 회선에서 2.7~3.0MB 지점마다 전송이 끊겨 앱이 부팅조차 못 함.
- 접근: 압축 파일 하나 + 스크립트 2개(시크릿 생성 → 설치 → 기동 → 접속 확인 자동, systemd 자동 재기동, Apache TLS 멱등 설정)로 완결되는 설치 체계. 사전압축(gz/br) + Accept-Encoding 협상, 난독화를 앱 청크로 한정, 로그인 화면은 main 청크만 로드하고 에디터 본체는 인증 뒤 lazy 로드, 토큰-세션 결속으로 공용 계정 상호 로그아웃 방지. 고객 데이터 사본 위에서 업그레이드 리허설을 먼저 수행.
- 개선: 로그인 전 전송량 30.2MB(무압축) → gz 0.11MB. 2026-08 v0.5.0 원격 설치 → 49일 가동 후 10월 v0.6 재배포, 리허설에서 회귀 2건 사전 수리. [PR #1, #894~#899, 서울시설공단_HTTP접속_다중접속_안정화_재배포_2026-10-08]

9. 다중 사용자 협업 — 화면 단위 버전·동시편집 경고·화면 공개·연결 대체

- 문제: 단일 계정·단일 브라우저 전제. viewer까지 공용 프로젝트를 저장·삭제 가능, 두 세션이 같은 화면을 고쳐도 안내 없이 먼저 저장한 쪽이 이김, 통째 문서 저장(약 130KB)이 PGlite 16MB 붕괴 위험과 맞닿음, 연결 삭제가 확인 없이 즉시 하드 삭제.

- 접근: 요구사항 정본(열기 O1~O8·저장 S1~S7·버전·동시편집·권한)을 인터뷰 3라운드로 확정하고 ADR 3편으로 기록. 동시편집 감지는 실시간 공동편집 대신 presence 하트비트로 결정하되, 고객 서버에서 요청당 CPU(HTTP 3.1ms vs WebSocket 0.013ms)를 먼저 실측해 근거 확보. project_screens·screen_versions 분리(저장 쓰기 약 60KB), 화면별 공개/비공개 + "직원 눈으로 보기", 게시 요약과 게시 순간을 서버 트랜잭션으로 대조(409). 연결은 소프트 삭제 + 대체 연결 지정, 순환·종류 검사는 FOR UPDATE 트랜잭션.
- 개선: 스택 PR 30여 건으로 다중 사용자 운영 구조 전환. 통합본 서버 시험 1,627건·vitest 15,677건 통과, 관리자/열람자 두 오리진 실측. [PR #969~#1004, #1070~#1076, #1088~#1094, docs/adr]

10. 서버 아키텍처 정리·테스트 인프라
- 문제: 7천 줄 모놀리스 서버의 DB 분기(mysql/pg/oracle) 71곳이 복제돼 엔드포인트 하나를 고칠 때 3~6벌 수정. 조사에서 pg 풀 클라이언트 end() 호출로 풀 파괴 7곳, MySQL 풀을 import조차 안 해 29개 분기가 요청마다 TCP 신규 연결. HTTP 시험이 고정 포트로 떠서 다른 워크트리의 서버를 상대로 도는 플레이크.
- 접근: 골든 계약 하네스로 현행 응답을 바이트 수준 고정한 뒤 순수 계층(방언·페이징·카탈로그 SQL 13종×3방언) → 어댑터 → 실행 심(연결 반납 불변식 1곳)으로 점진 이행. 테스트 서버 기동 도우미는 부모가 빈 포트를 고르고 자식 stdout의 listen 줄을 대조한 뒤에만 준비 완료로 판정. TS AST로 마이크로 테스트 파일 55개 → 11개 자동 병합.
- 개선: 읽기 메타 10종 이식, index.js 504줄 순감, 3DB 골든 diff 0. 플레이크 재현 → 0건, 리포 규칙으로 승격. CI 3 워크플로(단위 → MySQL 통합 → E2E, 서버, RAG 계약) + 실 PG 잡. [PR #277, #278, #933, #474]

11. 고객·QC 피드백 대응 — 입력 검증·모바일·지표 패널·조회조건 통합
- 문제: 입력 15종에 검증 개념이 없어 빈 값이 NULL 리터럴로 치환되거나 조건이 통째로 건너뛰어져 "필터를 걸었는데 전체가 나오는" 무음 오답. 모바일 390px에서 KPI 앞자리·차트 글자 잘림. [조회] 버튼에 연결되지 않은 차트 재조회 불가.
- 접근: 검증 시점을 조회 게이트 + 인라인 표시로 정하고 순수 함수 계층으로 구현. 폰은 모두 한 열, KPI는 넘치면 억·만 단위 축약(전체 값은 aria-label), 폭 3종 × 화면 3종 잘린 글자 자동 검사 E2E. 지표 패널은 "데이터는 KPI 엔진, 표시는 패널+요소"로 통합하고 내장 템플릿으로 1분 안에 타일 구성. [조회] = 그 입력을 읽는 위젯 전부, 칩은 조회에 쓴 값 표시.
- 개선: QC 결함 9건 전부 origin/master 재현 후 수리(13 PR), 모바일 E2E 수리 전 9/9 실패 → 통과, PGlite TIMESTAMP −9h로 세션이 9시간 조기 만료되던 결함 수리(오차 0분). [PR #1109, #1116, #1140~#1146, #1017, #1184~#1189]

일하는 방식

- 작업기록: 조사·설계·구현·실측 산출물을 날짜 붙인 문서로 리포에 고정(362편 + HTML 88편). 실측 문서는 환경·명령·수치·"계획과 다른 점"까지 기록.
- PR 5요소: 문제 / 접근 / 범위 / 검증 / 남은 위험. 측정이 틀렸으면 본문에 정정을 남김.
- TDD·red-first·뮤턴트: 슬라이스마다 실패하는 시험 → 구현 → 가드 제거 뮤턴트 사망 확인. 검증 대상은 경계 산출물(전송된 SQL·저장 레코드).
- 실엔진·실측 우선: Docker 테스트 DB 4~6종으로 생성 SQL을 실제 실행, 브라우저 실측 표를 PR에 첨부, 고객 서버에서 부하·CPU 시간 측정 후 설계 결정.
- AI 코딩 에이전트 운용 (표기 여부 결정 대기): 구현 에이전트와 교차검토 에이전트를 역할 분리해 운용, 의뢰서 양식 고정, 지적은 재현 후 확인/반증/불확실로 분리 보고(최대 13차 왕복).
- 1차 자료 조사 후 설계: 업계 BI 6종 상한 정책, Power BI/Tableau 내보내기 범위, DB별 쿼리 취소 API를 공식 문서로 조사한 뒤 설계.
- 비개발자 소통: 결정 라운드 "쉬운 설명" HTML, 사용자 메뉴얼 36개(초보자 기준), 노션 QC 목록 대조.